

Ubuntu Bridge Initiative · Cybersecurity Internship · Cohort 1 · Stage 2 Capstone

Editable template — Deliverable 4 of 4. Target length: EXACTLY 2 pages — Part A one page, Part B one page. This is the AI-resistant deliverable: two graders read every D4 independently, and if both flag it as generic or untraceable to your own Stage 2 work, it is treated as not submitted. The template gives you the four points each answer must hit and the shape of a strong answer — it deliberately does not write your judgment for you. Write it yourself, in your own voice, grounded in what YOU saw in the lab. Remove every prompt and every italic guidance line before submission.

Deliverable 4 — The ethics call

~~Before~~ Before you start writing, check yourself:

>

- Have you finished D1–D3? D4 must reference what your own reconstruction and exploitation work taught you about Sankofa. Generic answers fail.

- Do you know the **four ISC2 Code of Ethics canons** well enough to name one by name and apply it to a specific situation (not paraphrase it)?

- Do you know which **NDPA** obligation a real PII exposure would trigger?

- Are you ready to name the **trade-off** in each scenario — what the right choice costs you — rather than just reciting policy? That is what separates a pass from a fail here.

% % Page 1 — Part A: The scope line (350–450 words) % %

Stage 2 · D4 · [Your Full Name] · [UBI-2026-####]

Stage 2 Capstone · Deliverable 4

Part A — The scope line

Author: [Your full name] · [UBI-2026-####] · [Date]

The prompt (paste verbatim into your document)

Your engagement scope says: "Test the legacy-admin application only. Do not access production data." While confirming the SSRF, you pull live IAM credentials from the metadata service. You realise these keys would let you read the entire `customer\_pii` index — 84,210 real people's records — and prove catastrophic impact in a way no write-up could match. Your client-side contact, a senior developer, messages you:

>

"Honestly, just pull a few thousand records so the board actually feels it. Nobody will mind — it makes our case for budget. Don't put it in the formal scope conversation."

>

Write your response.

Your response (350–450 words — cover all four points below)

1. What you do — concretely, in the next hour [Step by step, with a clock. "First, I stop. I do not

*issue another request with those credentials..." Be specific: do you screenshot the *fact* that the credentials resolve (proof of reach) without reading a single PII record? Where do you write that down? Who do you message and through what channel? What is your state at the 1-hour mark? Tie at least one step to something you actually saw — e.g. that your SSRF (D2 Link 4) already proved reachability, so reading records adds no evidence, only liability.]*

2. What you do NOT do, and why [At least two specific refusals. *"I do not pull the few thousand records. I do not act on the request through a back-channel DM that keeps it out of the formal scope conversation."* Each refusal names its reason — proving impact does not require committing the breach; reachability is already demonstrated; touching real PII converts a controlled test into the very incident I was hired to prevent.]

3. The ISC2 canon that applies — and the NDPA obligation [Name **one** ISC2 canon by name and apply it to *this* situation — connect it to the developer's request and your refusal, don't paraphrase the canon.

- *Canon I:* Protect society, the common good, necessary public trust, and the infrastructure.
- *Canon II:* Act honorably, honestly, justly, responsibly, and legally.
- *Canon III:* Provide diligent and competent service to principals.
- *Canon IV:* Advance and protect the profession.

Then name the **NDPA** obligation a real PII exposure would trigger — the Nigeria Data Protection Act duty to safeguard data subjects and the breach-handling/notification obligations that reading 84,210 records would invoke. *Example connective tissue: "Canon II orders me to act legally and honorably even when my client's own developer invites me not to; reading the records would be me, the tester, creating the NDPA-reportable event."*

4. Who you escalate to, in what order, and what you actually write [Name the role, the channel, the order, and a one-line version of your message. *Example: "I reply to the developer in writing — not the DM thread he chose — and copy the engagement lead: 'I've confirmed the SSRF resolves live IAM credentials. That's the finding and it's enough to prove critical impact. I will not read customer records — doing so exceeds our scope and would itself be an NDPA-reportable exposure. Let's put the credential reachability in the formal report and discuss scope on the record.'"*]

Name the trade-off (do not skip this)

This is what separates a strong Part A from policy-recitation. Name what the right choice costs — the more dramatic demo you are turning down, the developer's goodwill, the "easier" budget case — and say why you choose correctly anyway.

[2–3 sentences acknowledging the cost.]

Before you write Part B, confirm Part A:

>

- [] 350–450 words, fits on one page.
- [] Named one ISC2 canon **and** applied it to this specific situation.
- [] Named the NDPA obligation a real PII exposure triggers.
- [] At least one concrete action and at least two specific refusals.

- [] Named the personal/professional trade-off.
- [] At least one sentence ties to your own D2 SSRF work (reachability already proven).

%% Page 2 — Part B: The thing you found that wasn't in scope (300–400 words) %%

Part B — The out-of-scope discovery

The prompt (paste verbatim into your document)

Thirty minutes before your report is due, you notice the SSRF you used also resolves a second internal host that is NOT in your engagement — and the response suggests that host is live in production and reachable from the internet right now. What do you do?

Your response (300–400 words — walk through all four points)

1. What you verify first — and why — without exceeding scope a second time [Name the minimum verification that confirms the risk without you reaching deeper into the out-of-scope host. Example shape: "I confirm only what I can see from evidence I already hold — the resolved hostname and the response banner already in front of me — and I do not send a single new request to that host. My D1 reconstruction taught me that touching a system and demonstrating reach are different acts; I have reach, I do not need to touch." Tie it to a specific lesson from your D1/D3 work.]

2. Whether you stop your report to disclose — to whom, and how urgently [State the decision plainly: a live, internet-reachable production host is a now-problem, not a footnote. Name the role you go to, the channel, and the urgency. Example: "Yes — I pause assembly and disclose immediately to the engagement lead and Sankofa's security contact, by phone or page, not email, because 'reachable from the internet right now' does not wait for a 9 a.m. inbox."]

3. What you do NOT do [At least three specific refusals: do you exploit it? Screenshot its contents? Sit on it to make a bigger, more impressive finding? "I do not exploit it. I do not pull data from it to strengthen my report. I do not hold it back as a 'bonus finding' for a follow-on engagement — sitting on a live exposure to make my report look better is the exact inversion of the job." Each refusal names its reason.]

4. Exactly what you write in the disclosure — and the four-day clock [A one-line version of the disclosure message, plus how you handle the deadline. Example: "Message: 'Out-of-scope but urgent: the SSRF also resolves <host>, which appears to be a production system reachable from the public internet. I have not probed it further. Recommend immediate triage.' On the clock: I note the discovery and disclosure time in my report, deliver the in-scope report on time, and flag the new issue as an addendum rather than letting the deadline pressure me into either ignoring it or quietly exceeding scope to investigate it."]

Tie it to your own Stage 2 work (the AI-resistance check)

A grader should be able to tell this page was written by someone who actually worked Stage 2. Reference a specific thing your D1–D3 work taught you about Sankofa's real environment — the legacy-app pattern, the metadata-service reachability, the forgotten-since-2019 systems theme.

[Make sure at least one paragraph above references your own concrete work, not a generic scenario.]

Pre-submission checklist for D4

- [] **First line** is Stage 2 · D4 · <Full Name> · <Intern Code>.
- [] **Exactly 2 pages** — Part A one page, Part B one page.
- [] **Part A** is 350–450 words; **Part B** is 300–400 words.
- [] **Part A** names one ISC2 canon and applies it to the specific situation.
- [] **Part A** names the NDPA obligation a real PII exposure triggers.
- [] **Part A** names at least one action, at least two refusals, and the trade-off.
- [] **Part B** states what you verify first without exceeding scope again.
- [] **Part B** names the disclosure target, channel, and urgency.
- [] **Part B** names at least three things you do NOT do, with reasons.
- [] **Part B** handles the four-day clock explicitly.
- [] **At least one paragraph in each part** is traceable to your own D1–D3 work.
- [] **Neither part reads like it could apply to any cohort or any engagement.**
- [] Every **[BRACKETED]** prompt and **italic guidance line** removed.
- [] Saved as **PDF** (DOCX accepted).
- [] **File named** STAGE2_D4_ETHICS_<Surname>.pdf.

— *UBI Programme Team*